

Case Study — Cedar Park Family Medicine

HIPAA-Aware AI Receptionist

The challenge

Family medicine clinics field a high volume of calls that fall into a narrow set of categories — appointment booking, refill requests, insurance questions, and urgent triage — but every single one involves Protected Health Information (PHI). A generic voice agent that handles bookings well will fail an HHS audit on its first prescription refill. Production HIPAA voice AI is **20% conversational design and 80% vendor selection, PHI flow control, and audit-logging architecture**.

Goal: demonstrate not just a working voice agent, but the full engineering posture a regulated-healthcare client actually evaluates — including a documented BAA vendor matrix, a PHI flow audit, and a production-readiness checklist that maps the demo stack onto BAA-covered infrastructure.

The build

A HIPAA-aware AI voice receptionist ("Sage") that handles five conversation flows, every one of them gated on identity verification:

- **New patient intake** — demographics, insurance, chief complaint, new-patient visit scheduling
- **Existing patient booking** — name + DOB verification, then follow-up scheduling
- **Insurance verification** — plan capture, hand-off to billing team for eligibility check
- **Prescription refill request** — identity verification → medication + pharmacy → routed via secure message queue
- **Urgent triage** — distinguishes "needs same-day visit" from "dial 911 now" via a word-for-word escalation script

Every flow refuses medical advice, refuses any tool call before identity verification, and routes ambiguous cases to a human.

Stack

- **Voice platform:** Vapi (sub-second ASR + LLM + TTS pipeline) — **web Talk button only**, no phone number provisioned
- **LLM:** OpenAI GPT-4.1 with a 200+ line HIPAA-aware system prompt (5 flows, identity gate, 911 script)
- **Transcription:** Deepgram Flux General

- **Workflow glue:** Make.com (HTTP webhooks ↔ Google Calendar + secure message queue)
- **Calendar:** Google Calendar (PHI-minimal events, ID references only)
- **Secure message queue:** Gmail inbox in demo (synthetic data only); SQS + WORM-S3 in production design

Why no phone number?

Bright Smile Dental — the prior portfolio project — provisions a Vapi US phone number routed through Twilio. Cedar Park **deliberately skips phone provisioning** and uses Vapi's web Talk button. Reason: every component that touches voice data is a HIPAA Business Associate Agreement decision. Twilio does not sign a BAA at the free tier, and on the upgrade path it adds another vendor to the PHI-transit chain. The production migration documented in `BAA_VENDOR_MATRIX.md` re-introduces Twilio under a BAA-covered plan. The demo stays leaner on purpose.

How a refill request flows

1. Caller clicks "Talk to Sage" on the web demo
2. Sage answers in under one second: *"Thank you for calling Cedar Park Family Medicine..."*
3. Caller says: *"I need a refill on my lisinopril"*
4. **Identity gate:** Sage asks for first name, last name, date of birth — and is forbidden by the system prompt from making any tool call until those are supplied
5. Caller provides name + DOB
6. Sage asks for medication name and preferred pharmacy
7. Sage calls `secureMessage` (Make.com webhook) → request enqueues for the clinical team
8. Sage confirms the **request was sent** — explicitly does NOT confirm the refill itself, because only the clinical team can do that
9. Clinical team pulls the request out of band, calls back if a visit is needed

Total time: about 75 seconds including identity verification.

The HIPAA-grade differentiators

What separates this from a generic voice-AI demo:

Document	What it covers
<code>BAA_VENDOR_MATRIX.md</code>	Every vendor in the stack mapped to BAA availability, required plan tier, and recommended substitutions where the default doesn't qualify

Document	What it covers
<code>HIPAA_COMPLIANCE_AUDIT.md</code>	PHI inventory, encryption at rest and in transit, access controls, audit logging, 6-year retention, patient rights, breach protocol
<code>ARCHITECTURE.md</code>	Sequence diagrams (booking + refill flows), PHI flow map across demo vs. production stacks, production-readiness checklist

These three documents are the actual deliverables a clinic's compliance officer needs to sign off on before voice AI goes live — and the perspective a hiring client in regulated healthcare evaluates against.

Engineering decisions worth flagging

- **Identity verification gate** in front of every tool call. Calling `checkAvailability` before collecting DOB implicitly confirms "this person is one of our patients" to whoever holds the line — a PHI disclosure on its own. The system prompt enforces this with hard refusals.
- **PHI-minimal calendar events**: appointments store visit type and an internal patient ID in the event title, not name + DOB. The patient identifier registry lives separately.
- `secureMessage` **as a dedicated tool**, not an SMS or email. Prescription refills and triage have patient-safety implications; they need audit-logged routing, not best-effort dispatch.
- **GPT-4.1 over GPT-4o**: tighter tool-call adherence under strict verification-before-tool rules. With GPT-4o, Sage occasionally called `checkAvailability` before collecting DOB — a HIPAA risk.
- **Word-for-word 911 script** for emergency markers (chest pain, stroke signs, suicidal ideation, severe bleeding). Hard-coded wording is easier to audit than improvised triage.

Outcomes

Metric	Result
Production-ready conversation design	5 flows, all identity-gated
End-to-end booking time	~75 seconds (web) including identity verification
Cost per call (demo stack)	~\$0.05
Documents delivered alongside agent	3 — BAA matrix, compliance audit, architecture
Production migration path	Fully documented, vendor by vendor

Try it yourself

- 🌐 **Live demo site:** *deployed at <https://cedar-park-family-medicine.vercel.app>*
- 🗽 **Loom walkthrough:**
<https://www.loom.com/share/123b6387572949bc99a171db7619a1e2>
- 📄 **Code + docs:** <https://github.com/waseem253/cedar-park-family-medicine>

About me

I'm **Waseem Iftikhar** — an AI Voice Agent engineer with 7 years of production Python backend experience, including prior work on a HIPAA-compliant US healthcare practice-management system.

- **Confiz** (current) — Principal Software Engineer building a Google Vertex AI image platform on FastAPI + GCP
- **PRG** — Principal Software Engineer / Team Lead on a HIPAA-compliant US healthcare practice management system on AWS (full compliance audit + production deployment)
- **10Pearls** — Senior Software Engineer on Appraise Connect (Nationwide Appraisal Network), onboarded 3,000+ appraisers in month one

I build voice receptionists, lead-qualification agents, and HIPAA-aware medical voice AI for clinics, agencies, and SaaS companies.

Hire me on Upwork: <https://www.upwork.com/freelancers/~0166938f759e168a91>